

Operationalizing AI Assurance: Translating Maturity and Risk Frameworks into Measurable Practice

Dillon Bowes^a, Josh Harguess^b, Chris Ward^b

^aUniversity of California San Diego, La Jolla, CA, USA

^bFire Mountain Labs, San Diego, CA, USA

ABSTRACT

As artificial intelligence becomes embedded in defense, infrastructure, and enterprise systems, organizations face growing pressure to demonstrate responsible and verifiable adoption. Bridging the gap between high-level theory and operational practice, this work introduces a heuristic framework for translating qualitative models of AI maturity and risk management into measurable, evidence-based assurance exemplars. The framework decomposes AI assurance into six standardized pillars to enable consistent evaluation of governance, robustness, and security across organizational contexts. By establishing diagnostic benchmarks and repeatable assessment criteria, it supports more transparent communication of AI assurance posture and guides remediation efforts in alignment with evolving industry and regulatory expectations.

Keywords: AI assurance, AI governance, maturity models, AI risk management, operational AI

1. INTRODUCTION

The rapid deployment of artificial intelligence systems across sectors has vastly outpaced the operationalization of corresponding governance, risk, and assurance practices.¹ While numerous AI governance frameworks exist, organizations consistently struggle to translate high-level principles into measurable, defensible implementation states. This ambiguity complicates internal decision-making, stalls regulatory readiness, and prevents meaningful cross-organizational benchmarking.

Existing foundational frameworks, such as MITRE’s AI Maturity Model (AIMM)² and the NIST AI Risk Management Framework (AI RMF),¹ provide indispensable high-level guidance. MITRE AIMM outlines six critical pillars covering governance, risk, and operational considerations, while NIST AI RMF introduces functional categories (Govern, Map, Measure, Manage) for identifying and mitigating AI risks. These frameworks serve as effective reference architectures and conceptual benchmarks, particularly for setting organizational strategy and performing due-diligence activities.

However, they are primarily descriptive rather than prescriptive. They establish *what* domains must be addressed but offer limited guidance on *how* to measure sufficient implementation. This limits their utility as tools for consistent measurement, diagnostic scoring, or comparative assessment across different operational environments.

To address this gap, this paper introduces a standardized, evidence-based AI assurance maturity model designed to operationalize these foundational frameworks. Rather than proposing a competing set of principles, the proposed model adopts MITRE’s existing pillar-based framework and extends it into a practical evaluation methodology. By mapping concrete organizational evidence—such as named executive sponsors, pre-deployment validation gates, and active model monitoring—to heuristic maturity states, the model enables organizations to assess their current posture and visualize their operational adequacy through diagnostic heatmaps. The result is a practical, repeatable, and defensible framework for prioritizing investments and guiding responsible AI adoption.

Further author information: (Send correspondence to Josh Harguess)
E-mail: dillon.bowes0@gmail.com, {harguess, chris}@firemountainlabs.com

2. BACKGROUND AND THE OPERATIONAL GAP

The rapid proliferation of artificial intelligence systems has prompted a global push to establish formal governance, risk management, and compliance structures. Initial efforts largely focused on articulating high-level ethical principles and normative goals, such as the OECD Principles on Artificial Intelligence³ and the foundational tenets of the EU AI Act.⁴ While these guidelines successfully established international consensus on the necessity of safe and trustworthy AI, they lacked the operational specificity required for organizational implementation.

In response, the field transitioned toward structured risk management frameworks. The NIST AI Risk Management Framework (AI RMF)¹ and its subsequent Generative AI Profile⁵ represent a significant advancement, organizing AI risk management into four functional core areas: Govern, Map, Measure, and Manage. Complementing these guidelines, the ISO/IEC 42001 standard⁶ establishes an international framework for an Artificial Intelligence Management System (AIMS), providing a certifiable approach to governing AI development and use. Similarly, industry-specific models from Gartner⁷ and CNA⁸ have provided organizations with reference frameworks for conceptualizing AI maturity.

However, despite the availability of these foundational frameworks, an acute “operational gap” remains. Empirical studies demonstrate that organizational alignment with high-level principles rarely translates smoothly into practice; technical deployment consistently outpaces the establishment of systemic governance, often leaving practitioners to manage risks ad hoc without institutional support.⁹ Organizations struggle to translate the descriptive guidance of NIST or the OECD into prescriptive, measurable implementation states.

Furthermore, early attempts at AI assurance heavily indexed on model-level evaluations—such as accuracy metrics, targeted bias testing, and model cards.¹⁰ While these technical validations are strictly necessary, they are insufficient for holistic enterprise assurance if the organizational structures governing their design, deployment, and ongoing monitoring are absent or immature. To bridge this gap, organizations require a structured maturity model that evaluates AI assurance not just as a property of individual models, but as an enterprise-wide capability.

3. THE MITRE AI MATURITY MODEL (AIMM)

To operationalize the high-level guidance of existing frameworks, this paper explicitly builds upon the MITRE AI Maturity Model (AIMM).² MITRE AIMM was selected as the foundational framework because it effectively decomposes abstract governance principles into concrete, assessable domains of organizational responsibility.

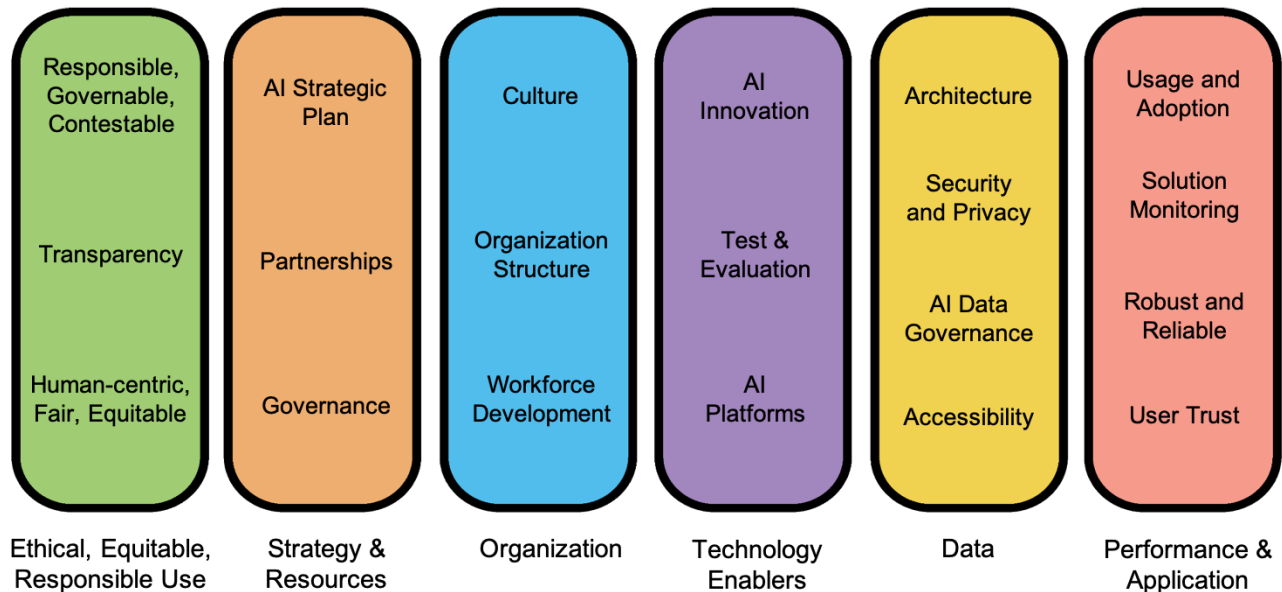


Figure 1. MITRE AI Maturity framework showing the six assurance pillars and their constituent capability domains.

The AIMM framework is structured around six distinct assurance pillars (Figure 1):

- **Ethical, Equitable, and Responsible Use:** Establishes the normative foundations for AI assurance, ensuring systems are governed by verifiable ethical principles and fairness measures. This pillar aligns closely with formal system design standards for ethical engineering, such as IEEE 7000.¹¹
- **Strategy and Resources:** Focuses on enterprise alignment, ensuring AI investments are formally governed, prioritized, adequately resourced, and linked to broader business objectives rather than isolated experiments.
- **Organization:** Captures the human enablers of assurance, demanding clearly defined roles, aligned incentives, and targeted workforce development to prevent assurance failures rooted in structural or knowledge gaps.
- **Technology Enablers:** Addresses the mechanisms that support controlled innovation at scale. This includes bounding experimentation with rigorous testing paradigms, such as AI red teaming,¹² and implementing standardized lifecycle controls across shared AI platforms.
- **Data:** Captures the stewardship, provenance, and protection of data. Because deficiencies in data governance directly undermine downstream model robustness and fairness,¹³ this domain is assessed independently of the models themselves.
- **Performance and Application:** Focuses on post-deployment operational realities. It tracks behaviors such as model drift, performance degradation, and user trust, which remain largely invisible during pre-deployment validation.

Within the MITRE AIMM framework, organizational capabilities across these six pillars are mapped to an ordinal maturity scale (Figure 2). Drawing on foundational capability maturity models,¹⁴ these levels range from Initial/Ad Hoc (Level 1) to Optimized (Level 5). These classifications reflect the degree of institutionalization, repeatability, and sustainability of assurance practices.

While MITRE AIMM successfully defines the *what* (the pillars and levels), the framework relies on adopters to define the *how* (the criteria for scoring). The following section introduces a standardized, heuristic evaluation methodology designed to translate this framework into an actionable diagnostic tool.

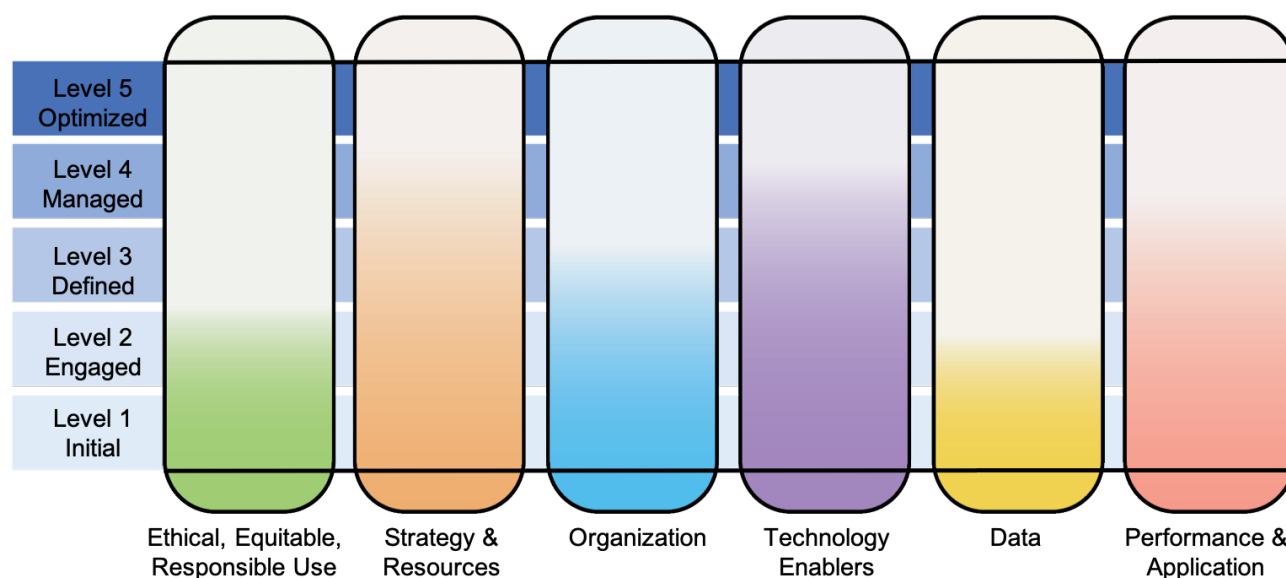


Figure 2. MITRE AI Maturity framework showing the defined maturity levels ranging from ad hoc practices to optimized and continuously improved assurance capabilities.

4. FRAMEWORK IMPLEMENTATION AND HEURISTIC SCORING

The principal limitation of existing frameworks is not conceptual completeness but operational ambiguity. While MITRE AIMM² defines maturity pillars, it does not specify how concrete organizational practices should be classified within those pillars or what constitutes sufficient evidence of implementation. NIST AI RMF¹ similarly avoids defining required artifacts, roles, or controls.

The proposed framework addresses this limitation by retaining six MITRE-aligned pillars while introducing standardized, evidence-based implementation criteria. Each pillar is evaluated using the same categories of assurance signals: ownership and accountability, policies and standards, processes and controls, documentation artifacts, and monitoring and review mechanisms. This structure allows observed practices to be consistently mapped, scored, and audited across organizations.

The framework evaluates each assurance pillar using a consistent set of standardized subcategories. These subcategories define the evidence signals used to assess implementation maturity and enable consistent scoring across organizations.

- **Roles and Ownership**

- Executive Sponsor: Named individual accountable for the pillar.
- Governance/Committee Oversight: Cross-functional or governance oversight body.
- System/Operational Owner: Named owner per system or model.

- **Policies and Standards**

- Governance Policies (ethics, accountability, strategy): Formal policies governing AI decision-making and lifecycle management.
- Regulatory & Compliance Standards: Standards aligned with legal, ethical, or fairness obligations.
- Technical & Operational Standards (security, robustness, data quality): Standards addressing technical development, security, and operational robustness.

- **Processes and Controls**

- Pre-deployment Governance (approval, validation): Structured pre-deployment review gates.
- Operational Risk Controls (mitigation, monitoring): Day-to-day risk mitigation and monitoring processes.
- Incident & Change Management: Structured handling of incidents and system changes.

- **Artifacts and Documentation**

- Governance Artifacts (charters, policies): Governance charters, ethical frameworks, and policy documentation.
- Operational & Technical Artifacts (model/data records): Model inventories, datasets, logs, and version histories.
- Assessment & Audit Reports (risk, validation, monitoring): Risk assessments, validation reports, and monitoring outputs.

- **Monitoring and Review**

- Performance & Risk Monitoring (pillar-specific KPIs): Quantitative indicators of performance and risk.
- Scheduled Reviews (periodic evaluations): Regular evaluations of governance, controls, and processes.
- Audit & Corrective Action (findings and remediation): Evidence of findings, follow-up, and corrective actions.

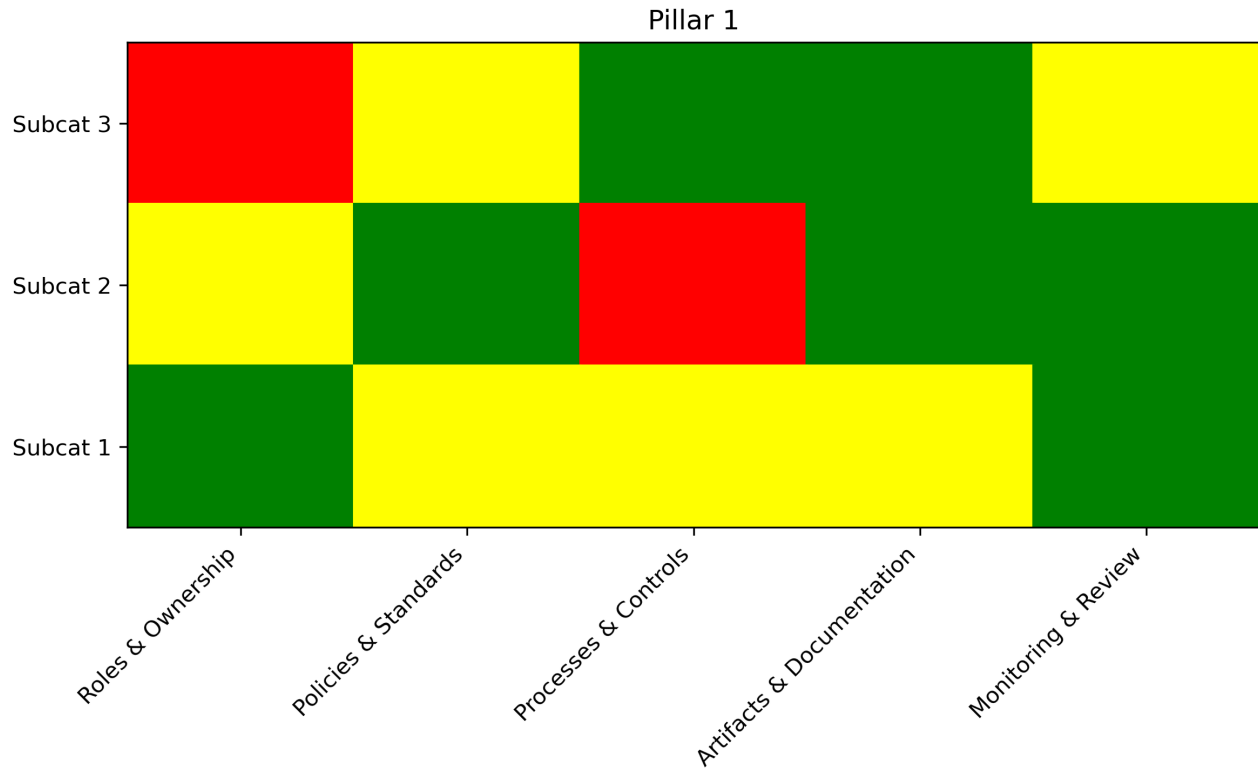


Figure 3. Exemplar heatmap presented to illustrate the general visualization framework, with comprehensive results and analysis provided in the Appendix.

4.1 Heuristic Evaluation and Categorization

Rather than relying on a rigid mathematical aggregation at this stage, the framework employs a qualitative, heuristic evaluation model to determine the maturity of each subcategory. Evaluators assess the presence, enforcement, and auditability of the evidence signals defined above and map them to three categorical states. These states correspond directly to the visual heatmaps used to profile organizational archetypes in subsequent sections:

- **Low Maturity (Red):** Practices are ad hoc, undocumented, unverified, or entirely absent. Any existing assurance relies on localized, individual contributor efforts rather than systemic, organizational controls.
- **Medium Maturity (Yellow):** Practices are partially implemented or currently emerging. While foundational policies or localized processes may exist, they lack enterprise-wide enforcement, comprehensive monitoring, or consistent artifact generation.
- **High Maturity (Green):** Practices are fully institutionalized, repeatable, and auditable. There is strong, verifiable evidence of enterprise-wide enforcement, regular review, and continuous improvement mechanisms.

By profiling a pillar across these subcategories, organizations can quickly visualize their operational adequacy. The density and distribution of these categorical scores (Red, Yellow, Green) act as a heuristic threshold to map the organization to a broader ordinal maturity level (Levels 1 through 5). A predominantly “Red” profile signifies an Initial/Ad Hoc state (Level 1), whereas a transition to predominantly “Yellow” and “Green” states signifies an Engaged (Level 2) and Defined (Level 3) capabilities.¹⁴

The formal quantitative algorithms and precise weighting mechanisms for deriving a composite AI Assurance Index (AAI) are deferred to future work, allowing the current framework to focus on immediate diagnostic clarity and evidence gathering.

5. EXEMPLAR ORGANIZATIONAL ARCHETYPES

To demonstrate the practical application of the heuristic evaluation model, we map three hypothetical, yet highly representative, organizational archetypes. These profiles illustrate how the presence, absence, or partial implementation of standardized evidence signals dictate an organization’s diagnostic heatmap and subsequent maturity classification.

To enhance interpretability of the composite heatmaps, maturity signals are not only aggregated but also discretized using a granular scoring function. Individual subcategories are first evaluated using a three-tier heuristic scale (Low = 0, Medium = 1, High = 2), after which scores are hierarchically averaged across signals, subcategories, and pillars, with all elements equally weighted. Because multiple subcategories contribute to each pillar score, this aggregation produces continuous values (e.g., 0.33, 1.17, 1.67) rather than discrete integers.

These averaged pillar scores are then mapped to a five-tier scale ranging from **Dark Red (0)** to **Dark Green (4)**, based on defined cutoff thresholds: Dark Red ≤ 0.4 ; Orange ≤ 0.8 ; Yellow ≤ 1.2 ; Light Green ≤ 1.6 ; Dark Green > 1.6 . For interpretability, each color band is mapped to a corresponding MITRE AIMM maturity level: Dark Red to Level 1 (Initial), Orange to Level 2 (Engaged), Yellow to Level 3 (Defined), Light Green to Level 4 (Managed), and Dark Green to Level 5 (Optimized). This prevents the collapse of results into coarse Low/Medium/High groupings and instead enables finer differentiation between early, intermediate, and near-mature states. The full set of underlying granular matrices, constructed at the individual signal level and subsequently averaged into the composites shown here, are provided in Appendix A. All underlying signals are treated with equal weight, and absence of evidence defaults to a Low (0) score, ensuring conservative maturity estimates.

5.1 Archetype A: The Experimental Adopter

Firm A represents an organization in the early, exploratory stages of AI adoption. AI initiatives are driven by localized engineering teams or individual contributors rather than a centralized, enterprise-wide strategy. Because of this grassroots approach, Firm A operates at an Initial/Ad Hoc state (Level 1) under the MITRE AIMM scale,² producing a composite diagnostic heatmap (Figure 4) that is **Low Maturity (Red/Orange)**.

Where Firm A does show signs of capability, it is heavily localized. They may exhibit isolated instances of **Medium Maturity (Yellow)** within the *Technology Enablers* or *Data* pillars, typically manifesting as data scientists running basic, ad-hoc bias scripts, implementing source control, or maintaining informal dataset logs. However, these technical practices are not institutionalized; they depend entirely on the diligence of individual developers and lack corresponding audit or monitoring mechanisms.

Ultimately, these isolated technical efforts are overshadowed by a systemic absence of formal governance. Firm A lacks named executive sponsors for AI risk, enterprise-wide AI policies, and standardized review gates prior to model deployment. Strategy is reactive and project-driven, and post-deployment monitoring is restricted merely to basic availability and uptime, leaving the organization largely blind to operational risks like model drift, bias, or performance degradation.

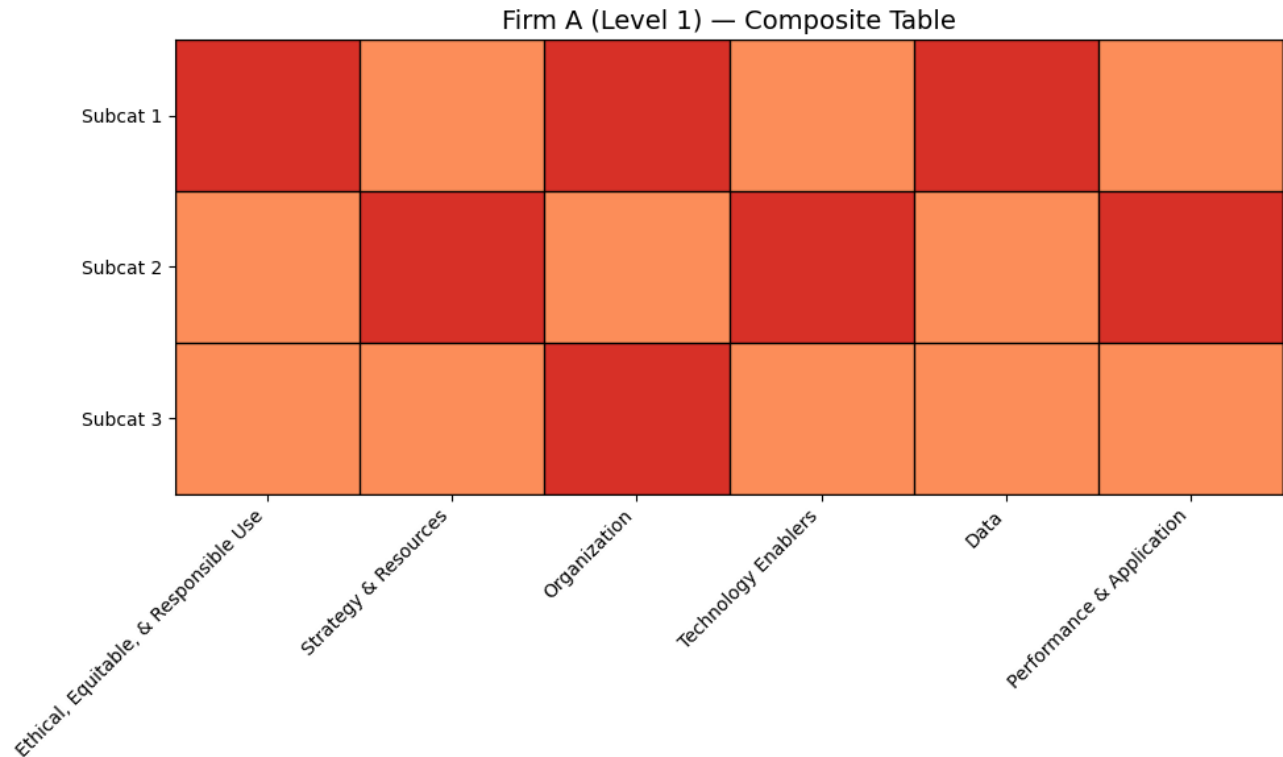


Figure 4. Composite diagnostic heatmap for Firm A (Experimental Adopter). Color bands reflect granular cutoff thresholds applied to averaged scores: Dark Red ≤ 0.4 ; Orange ≤ 0.8 ; Yellow ≤ 1.2 ; Light Green ≤ 1.6 ; Dark Green > 1.6 .

5.2 Archetype B: The Managed Integrator

Firm B represents an organization that has recognized the necessity of AI assurance and has begun implementing formal structures, but has not yet achieved consistent, enterprise-wide enforcement. Operating at an Engaged or Defined capability state (Levels 2 and 3), Firm B’s composite heatmap (Figure 5) is characterized by a high density of **Medium Maturity (Yellow)** signals, reflecting averaged scores that cluster in intermediate ranges due to partial but inconsistent implementation across subcategories, with a single subcategory scoring at the Orange level.

This archetype typically scores well in foundational areas like the *Organization* and *Strategy & Resources* pillars. Firm B has likely established a formal cross-functional AI governance committee and published foundational ethical charters. They have named an executive sponsor, documented an enterprise AI strategy, defined standard development lifecycles, and may even offer formal training programs for their data scientists and developers.

However, the “Managed Integrator” hits a bottleneck when it comes to execution. Their operational reality in the *Processes and Controls* and *Monitoring and Review* subcategories often lags significantly behind their documented policies. For example, while review gates exist on paper, their engineering pipelines lack automated enforcement, and post-deployment monitoring relies heavily on manual, periodic reviews rather than continuous telemetry.

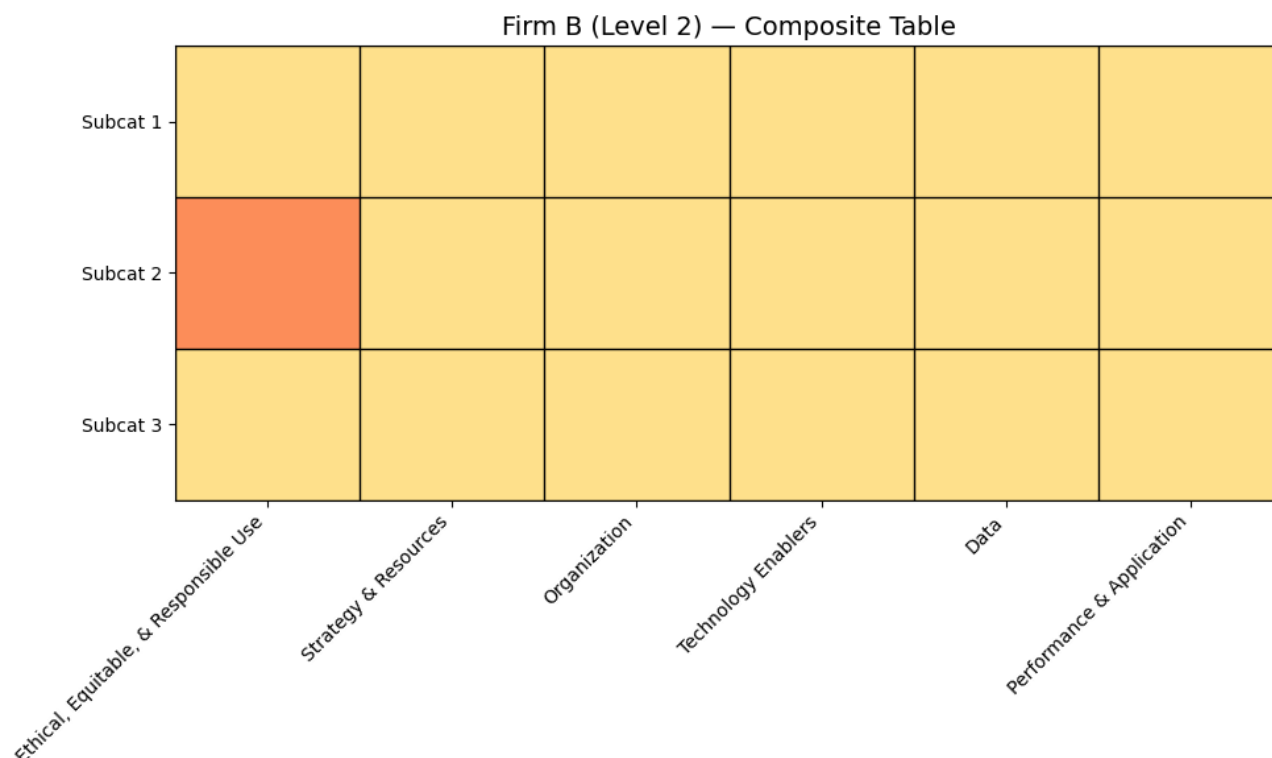


Figure 5. Composite diagnostic heatmap for Firm B (Managed Integrator). Color bands reflect granular cutoff thresholds applied to averaged scores: Dark Red ≤ 0.4 ; Orange ≤ 0.8 ; Yellow ≤ 1.2 ; Light Green ≤ 1.6 ; Dark Green > 1.6 .

5.3 Archetype C: The Optimized Enterprise

Firm C represents a mature organization where AI assurance is treated as a core operational competency, fully integrated into the enterprise risk management framework. Operating at a Managed or Optimized state (Levels 4 and 5), Firm C's diagnostic profile (Figure 6) is overwhelmingly **High Maturity (Green)**. Across all six pillars, evidence signals are highly visible, verifiable, and systematically enforced.

While Firm C demonstrates clear executive ownership, strict alignment with regulatory standards, and mandatory pre-deployment review gates, what truly separates them from Archetype B is the depth of their institutionalization. AI strategy is not merely documented; it is integrated directly with enterprise strategy as well as capital planning. Workforce development features enterprise-wide training, formal ethics programs, and certified competency frameworks. Furthermore, all models are tracked in a central inventory with auditable histories and formal decommissioning controls.

Most importantly, Firm C distinguishes itself in the *Monitoring and Review* subcategories. Risk metrics are continuously tracked, model drift triggers automated alerts, and regular independent audits consistently enforce corrective actions. Because these assurance practices are institutionalized, repeatable, and continuously improved, Firm C is able to operate reliably and resiliently at scale.

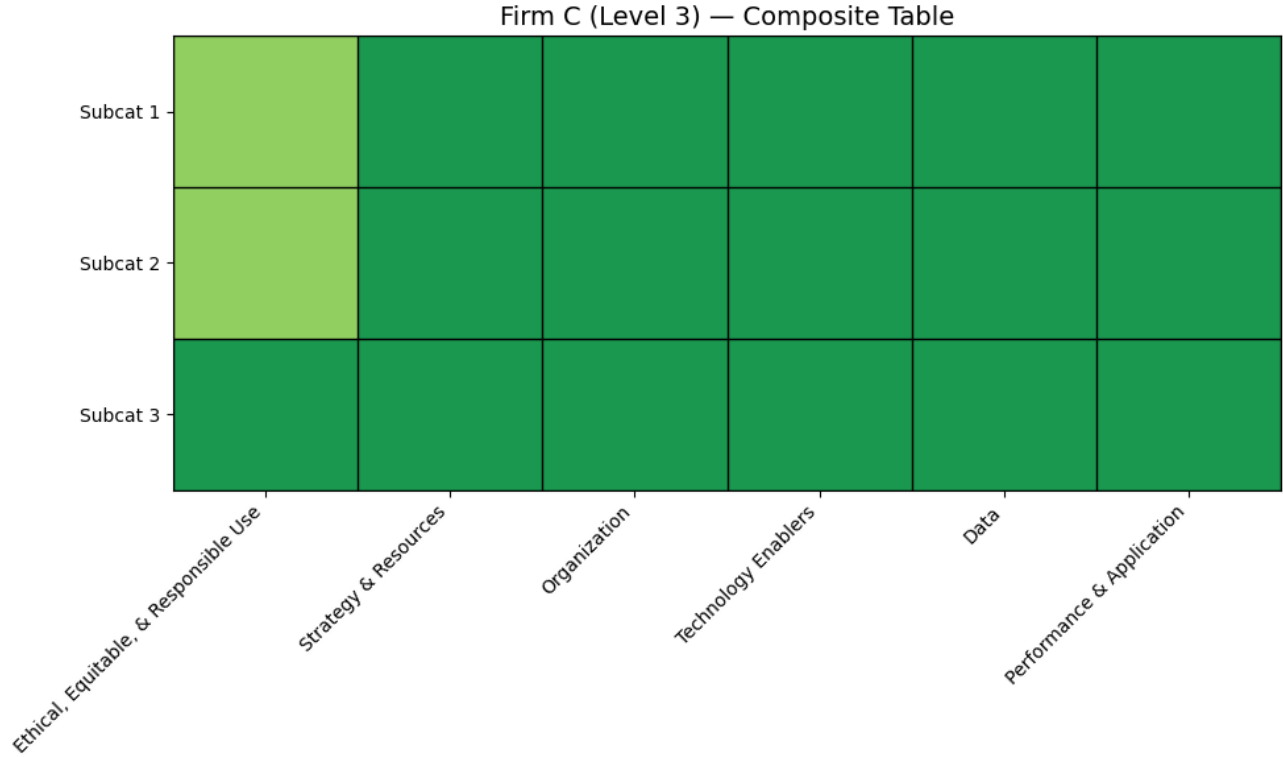


Figure 6. Composite diagnostic heatmap for Firm C (Optimized Enterprise). Color bands reflect granular cutoff thresholds applied to averaged scores: Dark Red ≤ 0.4 ; Orange ≤ 0.8 ; Yellow ≤ 1.2 ; Light Green ≤ 1.6 ; Dark Green > 1.6 .

6. DISCUSSION

The exemplar archetypes illustrate how the proposed framework enables structured comparison of organizational AI assurance postures while preserving sufficient granularity to understand why those differences arise. As established by foundational maturity models,^{14,15} aggregate classifications provide a necessary executive summary, but the underlying dimensional data is required for targeted remediation.

Although each archetype corresponds to a different overall maturity level, the heatmaps demonstrate that maturity is rarely uniform across pillars or subcategories. Organizations may exhibit relatively strong performance in some areas while remaining significantly underdeveloped in others. The heuristic scoring methodology therefore emphasizes the distribution of standardized signals rather than relying on any single indicator of capability.

6.1 Comparing Heuristic Profiles and Offset Effects

This property is particularly visible when comparing Archetype A and Archetype B. In the Experimental Adopter scenario (Archetype A), maturity signals remain uniformly low (Red). Even when isolated technical practices exist (such as basic validation scripts or model cards¹⁰), these signals appear within a broader context of missing governance structures and undefined ownership. As a result, localized strengths do not materially elevate the aggregate assessment of the pillar.

By contrast, the Managed Integrator (Archetype B) demonstrates how partial institutionalization of assurance practices influences the overall maturity profile. In several pillars, the presence of formal policies or governance committees raises the categorical score to Orange or Yellow despite gaps in technical enforcement. Because pillar evaluations consider multiple subcategories, strong performance in governance (e.g., establishing an AI ethics charter) can partially offset weaker implementation elsewhere (e.g., incomplete data lineage tracking¹³).

This behavior reflects the intended design of the framework: maturity evaluates the degree to which assurance practices are institutionalized, rather than demanding perfection of every single operational control from day one.

6.2 Divergent Implementations Yielding Similar Classifications

Another critical observation is that similar aggregate maturity classifications may arise from fundamentally different organizational configurations. Because the framework evaluates evidence signals across five distinct subcategories, two organizations could achieve a predominantly “Medium Maturity” (Yellow) profile for a given pillar while exhibiting entirely different internal strengths and weaknesses.

For instance, within the *Ethical, Equitable, and Responsible Use* pillar, one organization might emphasize strong, top-down governance structures (e.g., strict alignment with the EU AI Act⁴ or OECD Principles³) but lack mature technical bias-testing pipelines. Another might possess robust technical bias-mitigation tools but lack a formal ethics committee or executive sponsor. Both profiles may produce a comparable aggregate heuristic, even though their specific risk exposures and operational bottlenecks differ entirely.

This outcome is intentional. The aggregate maturity level serves as a summary indicator for benchmarking, while the subcategory-level heatmaps provide the diagnostic detail needed to interpret the result and guide investment. Conversely, organizations with superficially similar practices may be categorized differently depending on how consistently those practices are enforced. Nominal alignment with the NIST AI RMF¹ or MITRE AIMM² does not guarantee high maturity if these mechanisms operate irregularly or lack demonstrable oversight.

Taken together, the archetype comparisons highlight the principal advantage of the proposed heuristic model: it provides a repeatable method for summarizing organizational assurance maturity while preserving the contextual detail necessary for interpretation. By avoiding the assumption that complete maturity must be achieved simultaneously across all domains, the framework remains extensible and actionable.

7. CONCLUSION AND FUTURE WORK

As artificial intelligence continues to transition from experimental sandboxes to enterprise-wide deployments, the need for practical, auditable assurance frameworks has never been more acute. While foundational models like the MITRE AIMM provide essential structural guidance, organizations require prescriptive methodologies to translate these abstract pillars into measurable implementation states.

This paper addressed that operational gap by introducing a standardized, heuristic evaluation model. By decomposing AI assurance into six core pillars and assessing them against concrete evidence signals, ranging from executive ownership to automated monitoring, the framework enables organizations to visualize their maturity through diagnostic heatmaps. This categorical approach (mapping practices to Low, Medium, and High maturity states) prioritizes immediate diagnostic clarity and actionable remediation over complex mathematical abstractions. It demonstrates that effective AI assurance relies not just on localized technical validations, but on the enterprise-wide institutionalization of governance, policies, and continuous review mechanisms.

While the heuristic model provides a robust foundation for organizational benchmarking, it also establishes the necessary data-gathering groundwork for more rigorous quantitative analysis. Future work will expand upon this qualitative framework by introducing a formal, weighted scoring algorithm to calculate a composite AI Assurance Index (AAI). This subsequent research will explore empirical methods for determining subcategory weights, such as expert elicitation and regression analysis against industry breach data, enabling a more granular, mathematically defensible quantification of AI operational risk.

By separating the heuristic diagnostic from the quantitative algorithm, the proposed framework provides a practical, defensible, and highly extensible path toward responsible AI adoption across sectors.

REFERENCES

1. E. Tabassi, “Artificial Intelligence Risk Management Framework (AI RMF 1.0),” tech. rep., National Institute of Standards and Technology, 2023.
2. MITRE Corporation, “MITRE AI Maturity Model and Organizational Assessment Tool Guide,” tech. rep., MITRE, 2023.
3. OECD, “OECD Principles on Artificial Intelligence,” 2019.
4. European Commission, “Proposal for a Regulation on Artificial Intelligence (AI Act),” 2021.
5. R. Schwartz *et al.*, “Artificial Intelligence Risk Management Framework: Generative AI Profile,” tech. rep., National Institute of Standards and Technology, 2024.
6. ISO/IEC, “ISO/IEC 42001:2023 Information technology — Artificial intelligence — Management system,” standard, International Organization for Standardization, Geneva, Switzerland, 2023.
7. Gartner, “AI Maturity Model,” 2021.
8. Center for Naval Analyses, “Artificial Intelligence Maturity Model,” tech. rep., CNA, 2022.
9. B. Rakova, J. Yang, H. Cramer, and R. Chowdhury, “Where Do All the AI Ethics Principles Go? A Study of AI Practitioners’ Workplace Challenges,” in *Proceedings of the 2021 AAAI/ACM Conference on AI, Ethics, and Society*, pp. 792–803, 2021.
10. M. Mitchell *et al.*, “Model Cards for Model Reporting,” in *Proceedings of the Conference on Fairness, Accountability, and Transparency*, 2019.
11. IEEE, “IEEE Standard Model Process for Addressing Ethical Concerns during System Design,” Tech. Rep. IEEE Std 7000-2021, IEEE, 2021.
12. D. Ganguli, L. Lovitt, J. Kernion, A. Askell, Y. Bai, S. Kadavath, B. Mann, *et al.*, “Red Teaming Language Models to Reduce Harms: Methods, Scaling Behaviors, and Lessons Learned,” *arXiv preprint arXiv:2209.07858*, 2022.
13. T. Gebru *et al.*, “Datasheets for Datasets,” *Communications of the ACM*, 2021.
14. M. Paulk, B. Curtis, M. B. Chrissis, and C. Weber, “Capability Maturity Model for Software,” *IEEE Software*, 1993.
15. J. Becker, R. Knackstedt, and J. Pöppelbuß, “Developing Maturity Models for IT Management,” *Business and Information Systems Engineering*, 2009.

APPENDIX A. INDIVIDUAL PILLAR HEATMAPS

This appendix provides the detailed, pillar-by-pillar heuristic evaluations for the three organizational archetypes introduced in Section 5. These figures isolate the specific evidence signals (Ownership, Policies, Processes, Artifacts, and Monitoring) driving the composite maturity classifications. Pillar subsections follow the six MITRE AIMM pillars defined in Section 3.

A.1 Archetype A: Experimental Adopter

A.1.1 Pillar A1: Ethical, Equitable, and Responsible Use

Governance structures are informal and fragmented. There is no named executive sponsor for AI, no standing AI governance committee, and no documented governance charter. Oversight occurs, if at all, through general IT or cybersecurity forums without AI-specific mandates. Governance reviews are ad hoc, undocumented, and not integrated into enterprise risk management. Only individual teams occasionally apply local review practices, and accountability is unclear.

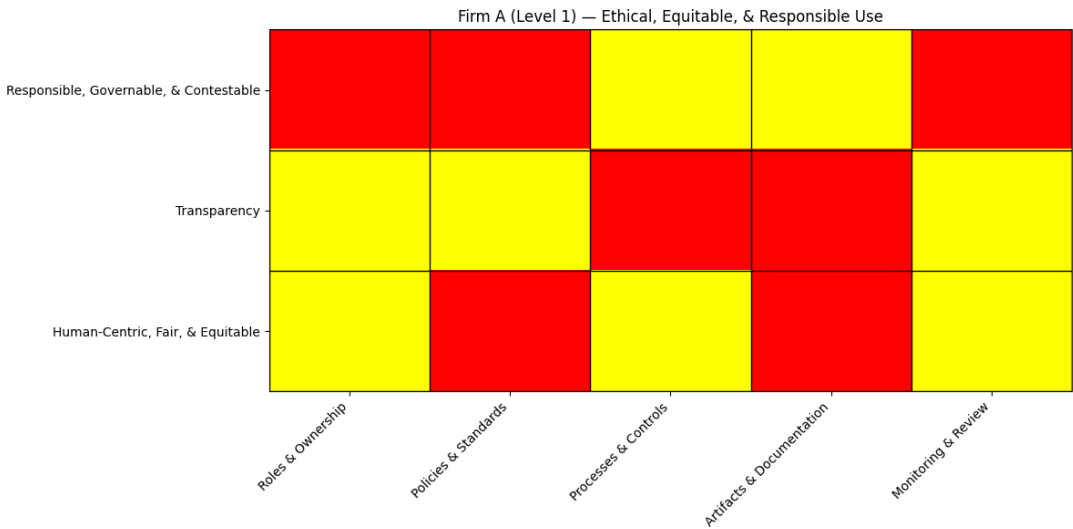


Figure 7. Heatmap legend: Red = low maturity, Yellow = medium maturity, Green = high maturity.

A.1.2 Pillar A2: Strategy and Resources

AI initiatives are opportunistic and project-driven. There is no enterprise AI roadmap, no documented linkage between AI investments and business strategy, and no formal portfolio management process. Funding decisions are reactive and made at the project level. Strategy is largely absent at the enterprise level, with only informal guidance from local project champions.

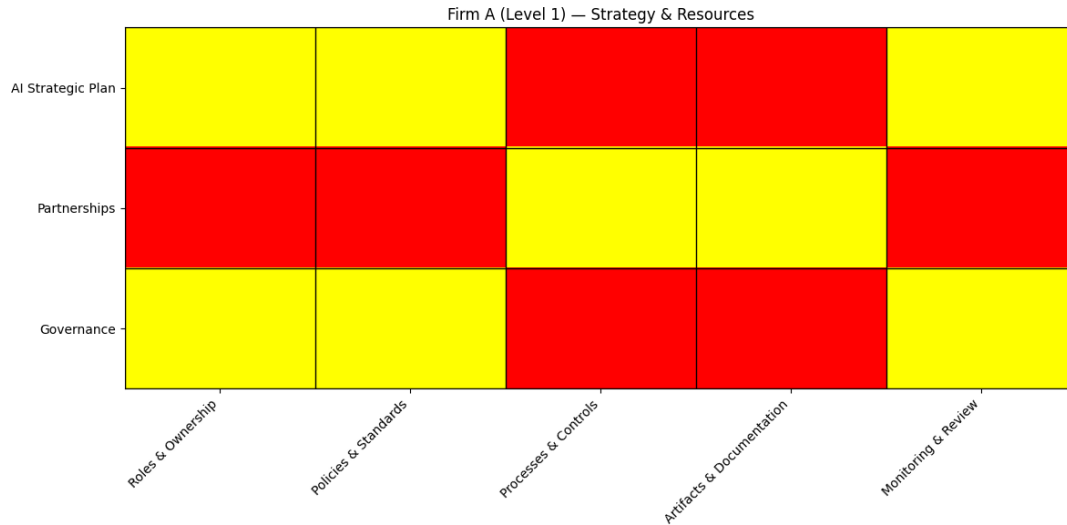


Figure 8. Heatmap legend: Red = low maturity, Yellow = medium maturity, Green = high maturity.

A.1.3 Pillar A3: Organization

AI capability is concentrated in small technical teams. There are no formal training programs, ethics training, or defined competency frameworks. Skills development depends entirely on individual initiative, with minimal knowledge sharing across teams.

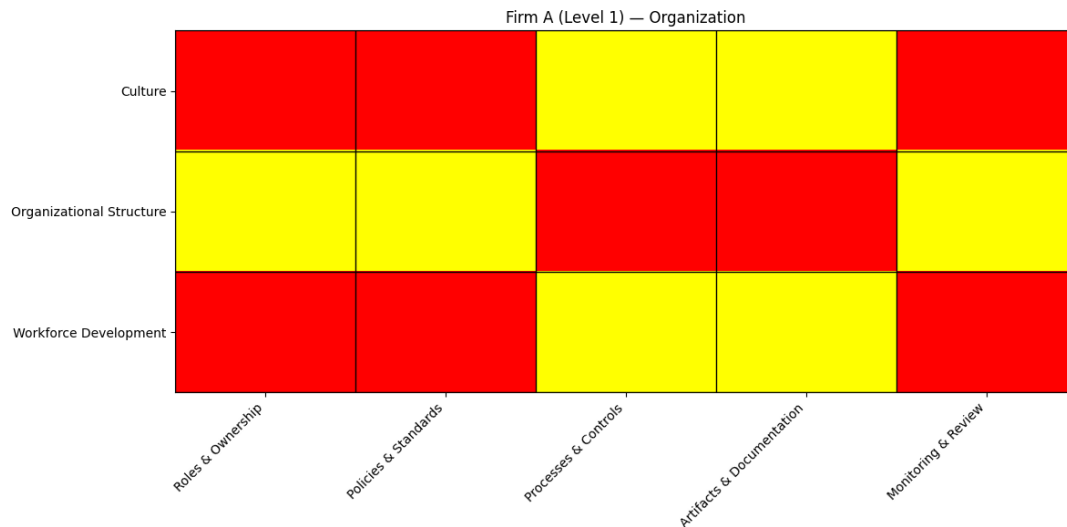


Figure 9. Heatmap legend: Red = low maturity, Yellow = medium maturity, Green = high maturity.

A.1.4 Pillar A4: Technology Enablers

Technology enablers are improvised rather than systematic. AI innovation is driven by individual researchers or project teams pursuing opportunistic experiments, with no shared systems engineering approach, human-machine design guidance, or enterprise R&D roadmap. Test and evaluation practices are inconsistent: some teams apply source control, unit testing, and ad hoc validation scripts, while bias testing, robustness testing, and security hardening are rare or absent, and no AI-specific T&E standards or pre-deployment gates govern how models are validated before release. AI platforms are undifferentiated from general-purpose IT infrastructure, with no dedicated MLOps tooling, model inventory, or lifecycle controls for versioning, change management, or

decommissioning; teams stand up pipelines and compute environments ad hoc, and the resulting practices are neither shared across projects nor auditable.

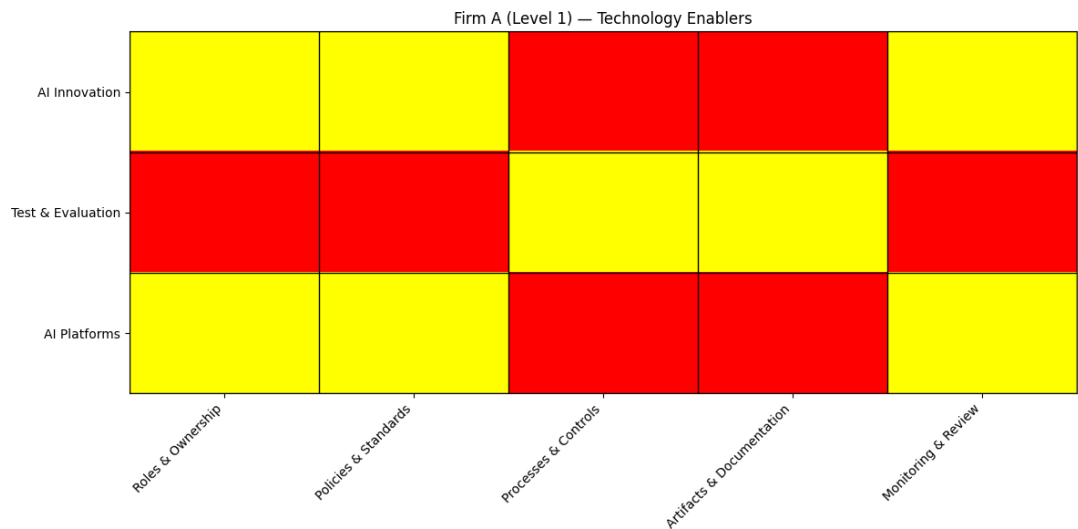


Figure 10. Heatmap legend: Red = low maturity, Yellow = medium maturity, Green = high maturity.

A.1.5 Pillar A5: Data

Data practices are fragmented and team-driven. No common data architecture or shared ingestion, storage, or lineage standards exist across the enterprise; individual teams assemble ad hoc pipelines and datasets for their own models. Data security and privacy controls are inherited from general IT policies rather than tailored to AI use cases, leaving gaps around dataset-level access controls and sensitive data handling in training data. Formal AI data governance is absent: there is no consistent record of datasets in use, no data cards or other standardized provenance or quality documentation, and no defined ownership for AI training data.

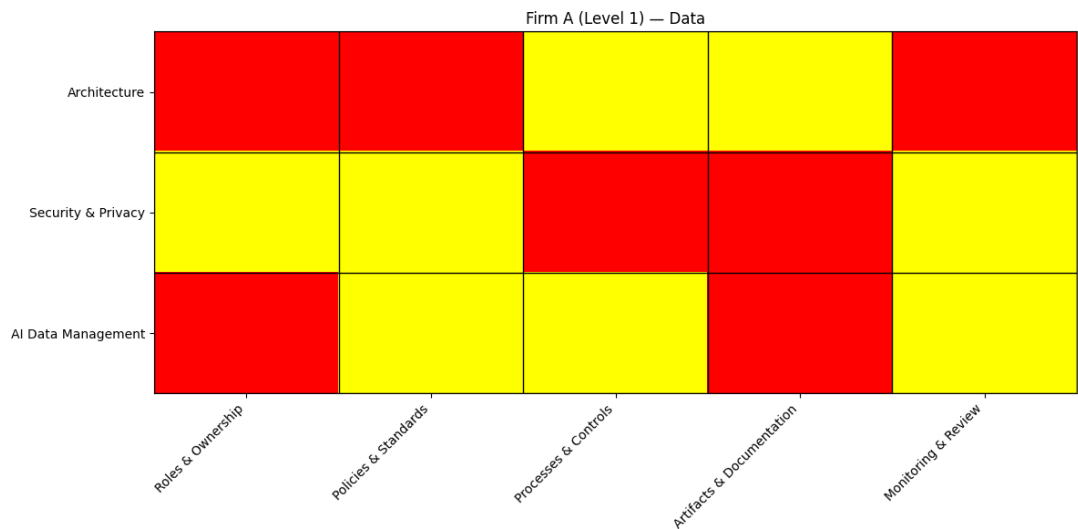


Figure 11. Heatmap legend: Red = low maturity, Yellow = medium maturity, Green = high maturity.

A.1.6 Pillar A6: Performance and Application

Post-deployment practices are improvised and minimal. AI business use cases are not formally documented, and no adoption metrics are tracked at the enterprise level. Solution monitoring covers availability and uptime only; drift, fairness, and anomaly signals are not instrumented, and incident response is informal or nonexistent. No AI-specific reliability standards govern production behavior, and user trust is unexamined: explainability, traceability, and trust calibration receive no due diligence.

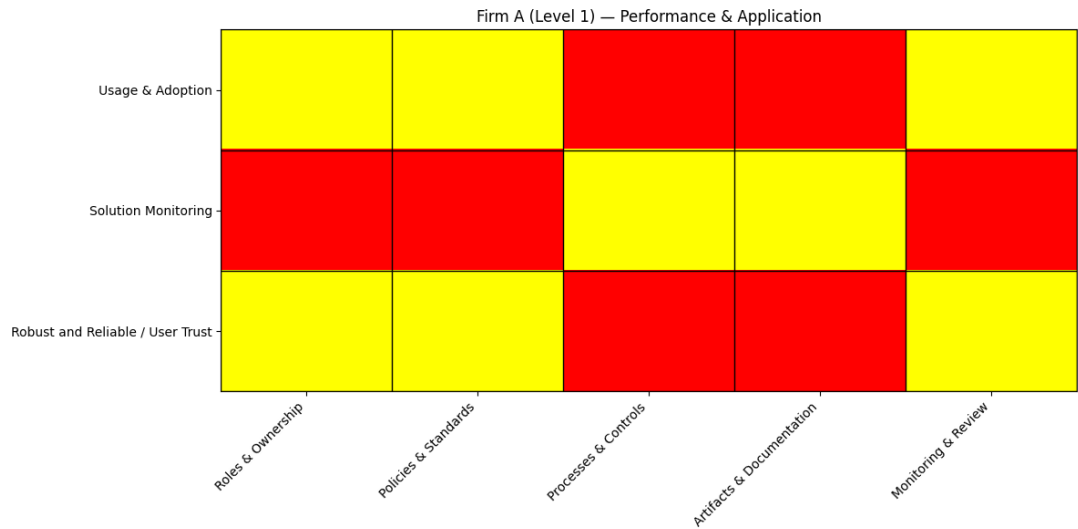


Figure 12. Heatmap legend: Red = low maturity, Yellow = medium maturity, Green = high maturity.

A.2 Archetype B: Managed Integrator

A.2.1 Pillar B1: Ethical, Equitable, and Responsible Use

An executive sponsor is named, and a cross-functional AI governance committee exists with a documented charter. Governance reviews are required for high-impact systems, but scope thresholds and enforcement vary by business unit. Accountability and oversight are partially formalized, though some processes remain inconsistent.

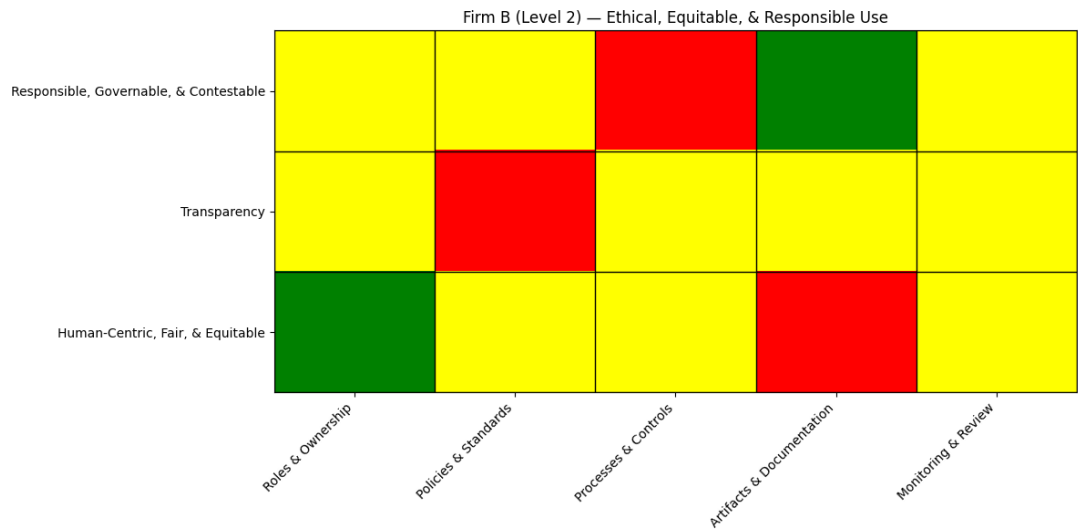


Figure 13. Heatmap legend: Red = low maturity, Yellow = medium maturity, Green = high maturity.

A.2.2 Pillar B2: Strategy and Resources

An enterprise AI strategy is documented and aligned to business objectives. Portfolio management exists for major initiatives, but prioritization criteria and benefit tracking are inconsistently applied. Strategy and planning exist but are not fully embedded across all teams.

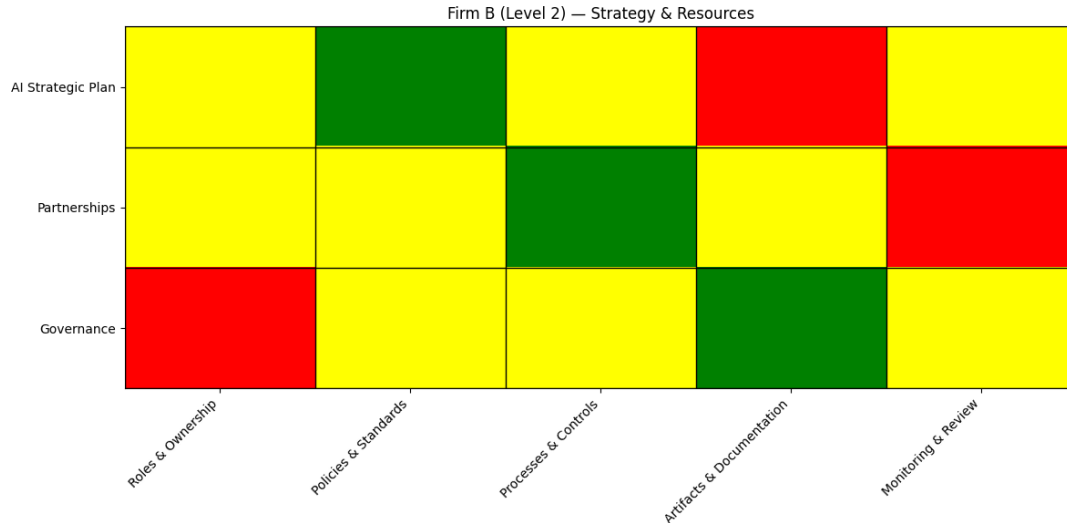


Figure 14. Heatmap legend: Red = low maturity, Yellow = medium maturity, Green = high maturity.

A.2.3 Pillar B3: Organization

Formal training programs exist for developers and data scientists, with ethics training provided for select roles. Competency frameworks are defined but not enforced enterprise-wide. Skills development is structured but unevenly applied.

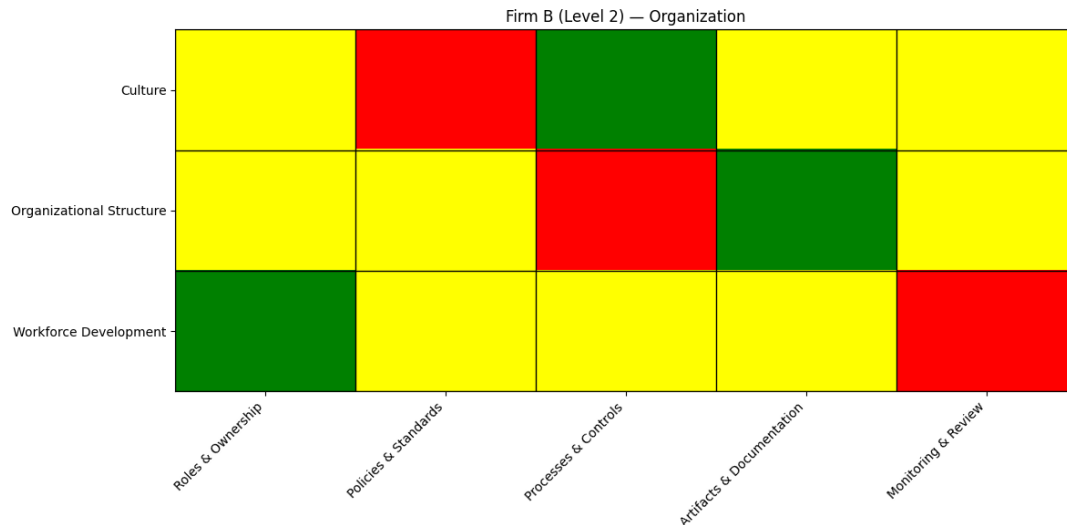


Figure 15. Heatmap legend: Red = low maturity, Yellow = medium maturity, Green = high maturity.

A.2.4 Pillar B4: Technology Enablers

Technology enablers are defined but inconsistently operationalized. An enterprise AI innovation approach is documented, with systems engineering guidance and human-machine design principles in place, though applica-

tion varies by team and R&D efforts remain partially siloed. Test and evaluation practices formalize AI-specific techniques: source control is universal, pre-deployment validation and approval gates are required for production systems, and bias testing and security checks are expected, though robustness testing and discrimination analysis (fairness testing) are applied inconsistently across critical and non-critical systems. AI platforms are consolidating onto approved MLOps tooling with standard experiment tracking and a central model inventory, and lifecycle controls for versioning, change management, and decommissioning are documented, though enforcement lags behind policy and parallel team-specific tooling persists in some units.

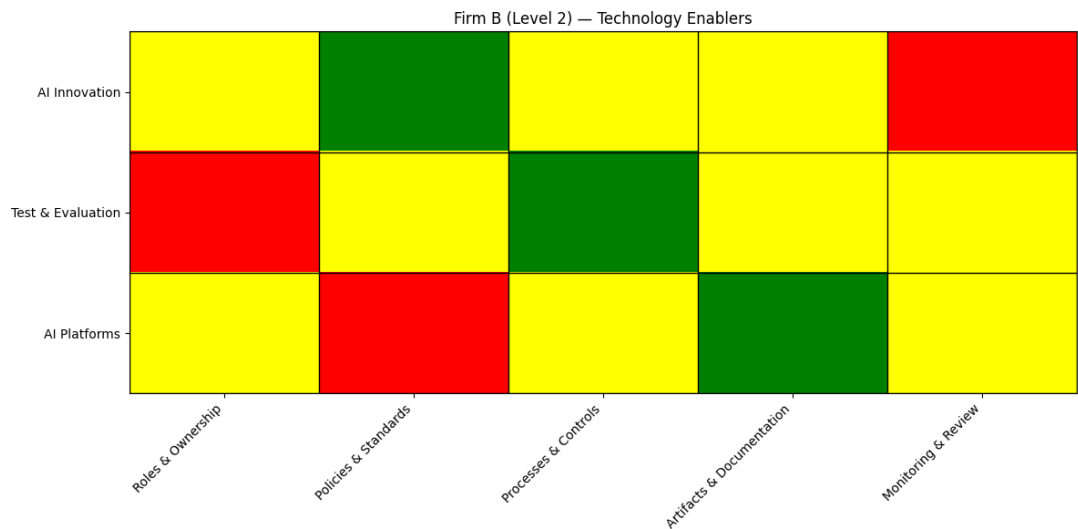


Figure 16. Heatmap legend: Red = low maturity, Yellow = medium maturity, Green = high maturity.

A.2.5 Pillar B5: Data

Foundational data standards exist but are unevenly enforced. An enterprise data architecture is documented, and most AI projects consume data through approved pipelines, though some teams continue to maintain shadow IT datasets and parallel data flows outside the governed architecture. Data security and privacy policies distinguish AI training data from general enterprise data, and access controls are enforced for sensitive datasets, but policy coverage lags behind the pace of new model development. AI data governance is formalized for designated high-value datasets: owners are named, quality checks run on a defined cadence, and provenance is recorded for production training data, though these practices have not yet been extended uniformly across all AI initiatives.

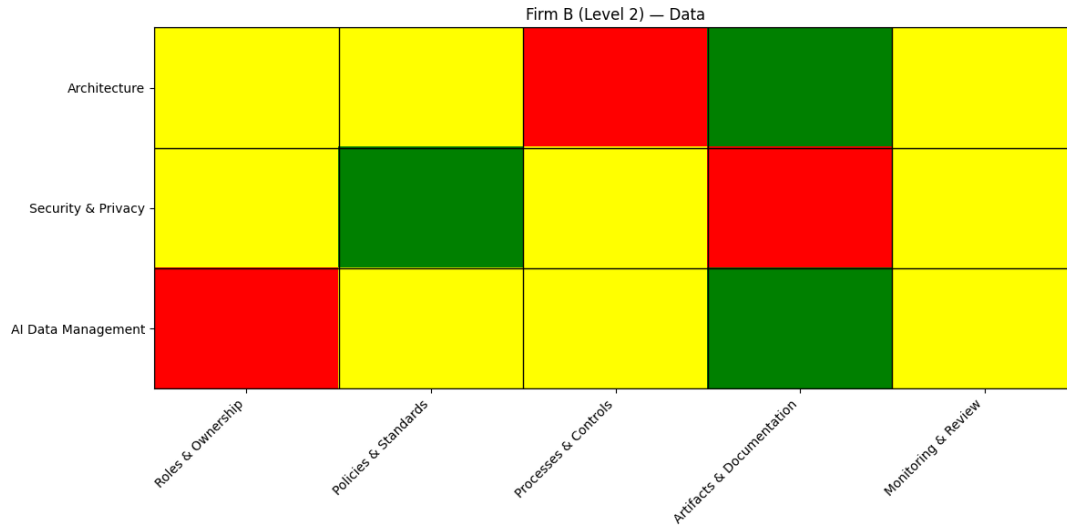


Figure 17. Heatmap legend: Red = low maturity, Yellow = medium maturity, Green = high maturity.

A.2.6 Pillar B6: Performance and Application

Post-deployment practices are defined but unevenly applied. AI business use cases are documented for priority initiatives and linked to workflow integration, though enterprise-wide adoption metrics are inconsistent. Solution monitoring tracks KPIs and AI-specific signals such as drift and fairness for production models, with scheduled reviews on an annual cadence, though remediation of audit findings is not consistently timely. AI-specific reliability standards exist and are applied to high-priority systems, and basic user trust practices (explainability documentation, traceability for key outputs) are in place, though coverage is uneven across the portfolio.

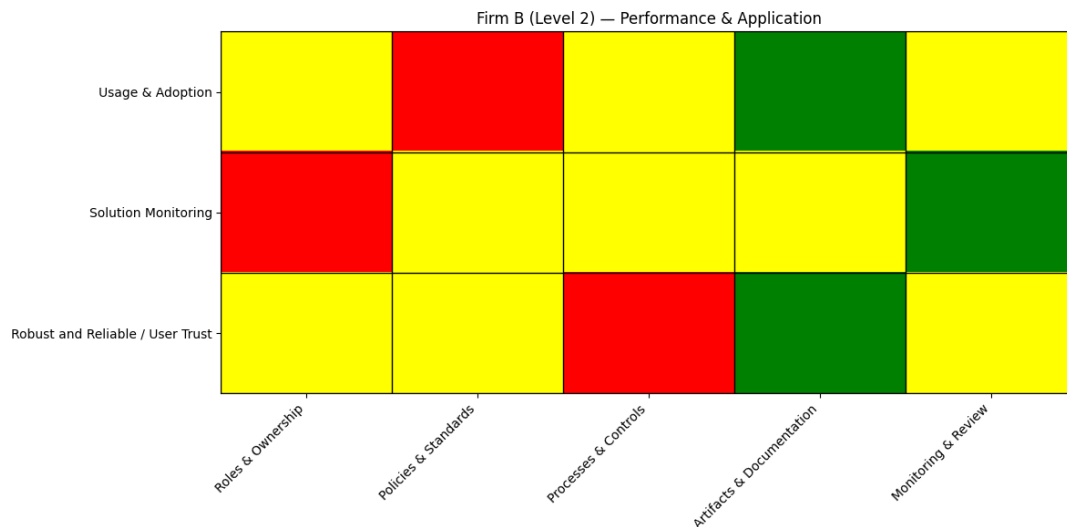


Figure 18. Heatmap legend: Red = low maturity, Yellow = medium maturity, Green = high maturity.

A.3 Archetype C: Optimized Enterprise

A.3.1 Pillar C1: Ethical, Equitable, and Responsible Use

Executive accountability is formalized through board-level oversight and standing AI governance committees. Governance reviews are mandatory for all production systems and integrated with enterprise risk management. Oversight is structured, with clear responsibilities and compliance mechanisms.

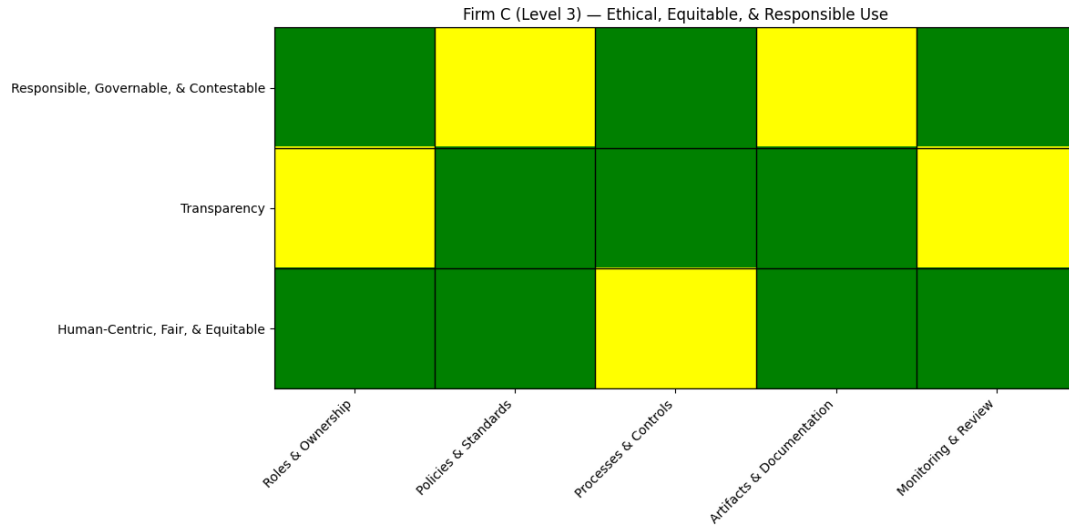


Figure 19. Heatmap legend: Red = low maturity, Yellow = medium maturity, Green = high maturity.

A.3.2 Pillar C2: Strategy and Resources

AI strategy is integrated with enterprise strategy and capital planning. Portfolio management, prioritization, and benefits realization are systematic and auditable. Strategy and planning are fully institutionalized across the organization.

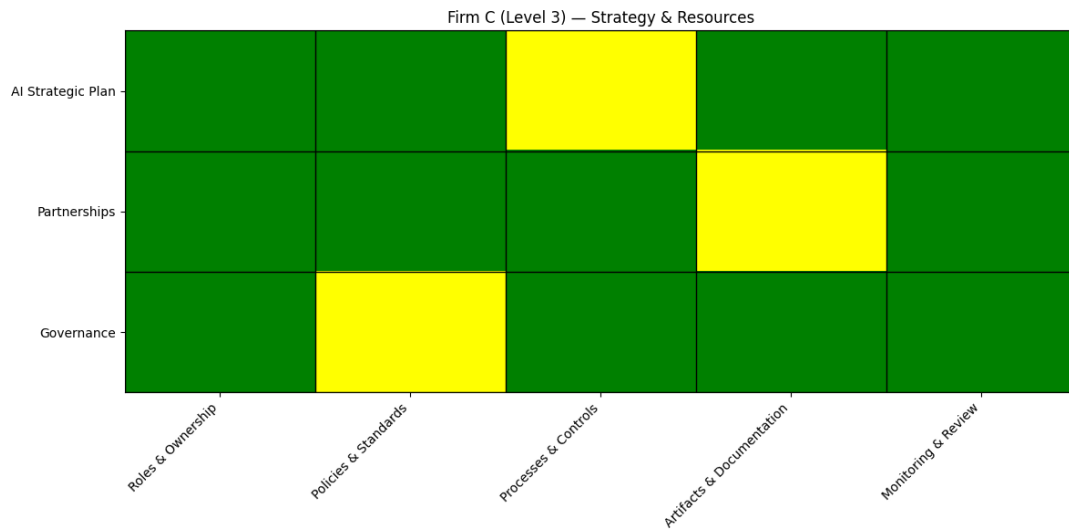


Figure 20. Heatmap legend: Red = low maturity, Yellow = medium maturity, Green = high maturity.

A.3.3 Pillar C3: Organization

Enterprise-wide training, ethics programs, certification paths, and role-based competency frameworks are enforced. Skills effectiveness is periodically assessed. Workforce development is structured and consistent across the enterprise.

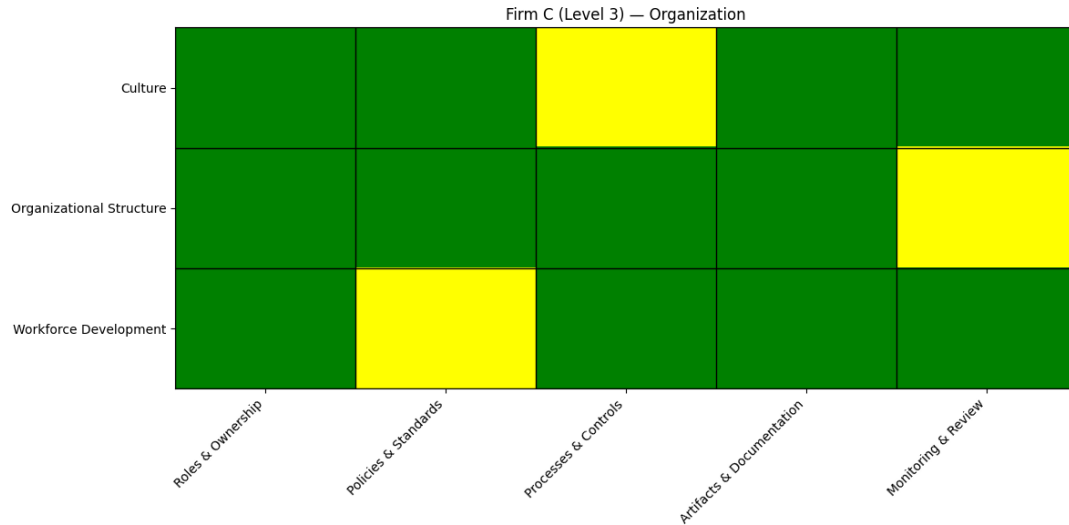


Figure 21. Heatmap legend: Red = low maturity, Yellow = medium maturity, Green = high maturity.

A.3.4 Pillar C4: Technology Enablers

Technology enablers are institutionalized and continuously refined. AI innovation is governed by a mature systems engineering and human-machine design practice aligned to enterprise objectives, with dedicated R&D programs, shared research infrastructure, and measurable innovation metrics. Test and evaluation is comprehensive and largely automated: basic testing practices (source control, unit testing, pre-deployment validation, and approval gates) and AI-specific testing practices (bias testing, robustness testing, discrimination analysis or fairness testing, and security hardening) are integrated into standard development pipelines, with T&E results audited against defined acceptance criteria. AI platforms are enterprise-wide and purpose-built for AI, providing standardized MLOps tooling, a central model inventory with auditable histories, and lifecycle controls that govern versioning, change management, and formal decommissioning for every production model; platform performance and adherence are monitored continuously and inform ongoing technology refreshment and infrastructure modernization.

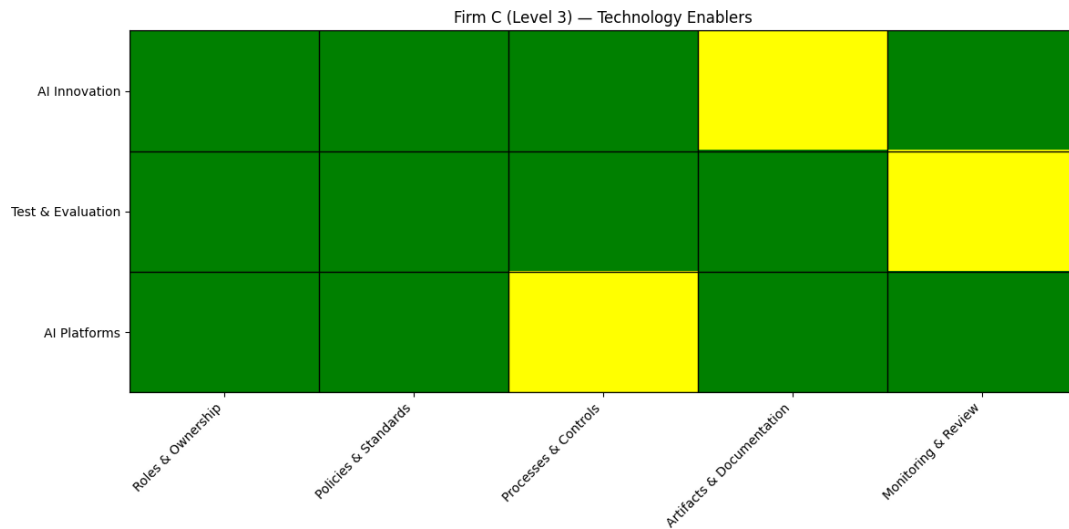


Figure 22. Heatmap legend: Red = low maturity, Yellow = medium maturity, Green = high maturity.

A.3.5 Pillar C5: Data

Data capabilities are institutionalized and continuously improved. A unified enterprise data architecture underlies all AI initiatives, with consistent ingestion, storage, and lineage services that track training data from source to deployed model. Data security and privacy controls are AI-aware and integrated with the enterprise security program, covering dataset-level access, sensitive data handling, and retention policies for training and inference data. AI data governance is comprehensive and auditable: every production dataset has a named owner, data cards document provenance and quality for all training data, automated quality checks gate ingestion into the governed architecture, and independent audits verify compliance on a regular cadence.

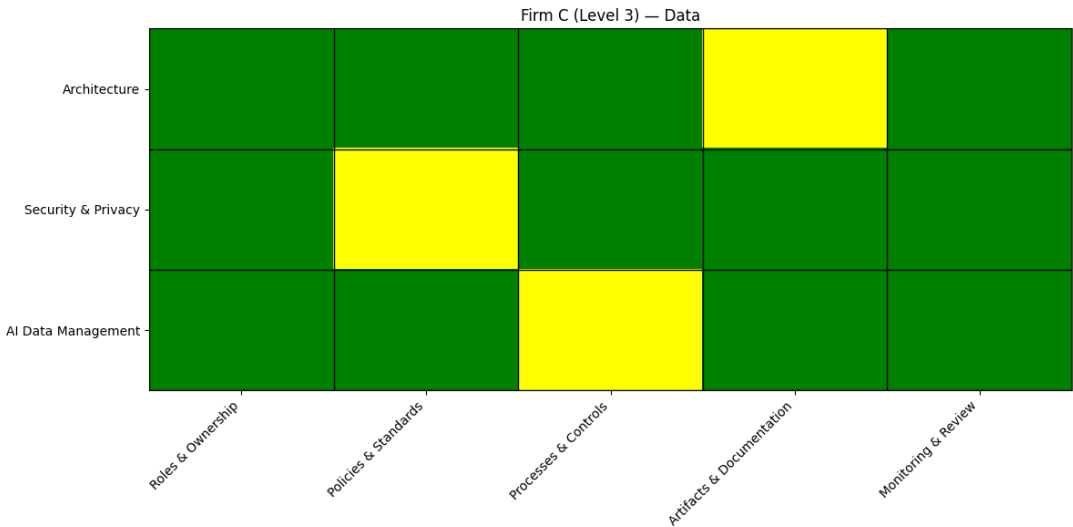


Figure 23. Heatmap legend: Red = low maturity, Yellow = medium maturity, Green = high maturity.

A.3.6 Pillar C6: Performance and Application

Post-deployment practices are institutionalized and continuously improved. AI business use cases are linked to enterprise KPIs across the portfolio, with quantified strategic outcomes and adoption metrics that inform future planning. Solution monitoring is continuous and automated: performance, risk, drift, fairness, and anomaly signals feed real-time alerts, scheduled reviews and independent audits are institutionalized, and remediation is tracked to closure with management reporting. AI-specific reliability and robustness standards are enforced enterprise-wide with regular audits, and user trust is actively managed through explainability, traceability, and user trust metrics (trust calibration) that are monitored at the enterprise level and improved based on incident analysis.

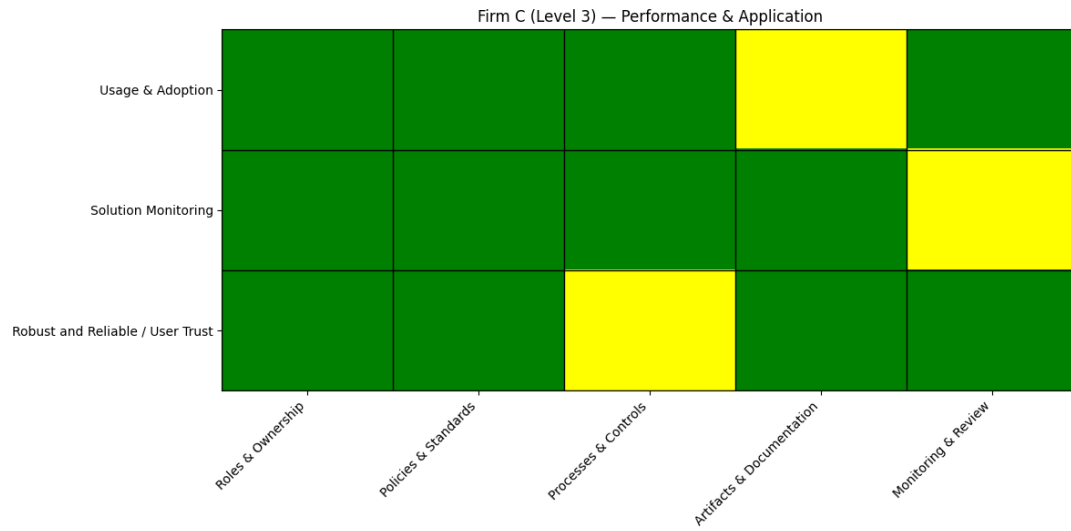


Figure 24. Heatmap legend: Red = low maturity, Yellow = medium maturity, Green = high maturity.